ATLAS TÉCNICO DEL SISTEMA

PORTADA · ÍNDICE · LEYENDA · MÉTRICAS VERIFICADAS

LÁMINA 00 / 10

ESCALA N/A · UNIDADES mm · FORMATO A4

A ÍNDICE DE LÁMINAS

Nº	PLANO	CONTENIDO	NIVEL
00	CARÁTULA E ÍNDICE	Portada, leyenda, métricas verificadas, glosario	—
01	CONTEXTO · C4 L1	Actores, sistema, servicios externos y protocolos	—
02	CAPAS Y CONTENEDORES	Siete capas, dirección de dependencia y superficies	L2
03	MOTOR DE INTELIGENCIA	Pipeline de escaneo, 12 etapas y modos de ejecución	L3
04	POOL DE IA	Routing por tarea, failover multi-proveedor, contratos	L3
05	MODELO DE DATOS	ERD del núcleo, tenancy, RLS y colas	L2
06	SEGURIDAD	Fronteras de confianza y defensa en profundidad	L2
07	REGLAS DE ORO	Constitución de ingeniería y su verificación	—
08	OPERACIÓN	Jobs, observabilidad, SIEM y respuesta	L2
09	FRAMEWORK	Stack, matriz de ajuste y decisión técnica	—

B LEYENDA DE SÍMBOLOS

- Flujo de datos / llamada síncrona
- Evento, job o dependencia asíncrona
- Frontera de confianza (trust boundary)
- Componente desplegable / módulo
- Almacén de datos (Postgres)
- JOB — Tarea programada (cron / Trigger.dev)

C MÉTRICAS VERIFICADAS

MÉTRICA	VALOR
Route handlers HTTP	78
Dominios de API	25
Páginas (App Router)	25
Tablas pgTable	78
Migraciones SQL	68
Archivos .trigger.ts	27
Task IDs declarados	34
Entradas cron	10
Tools registradas	43
Módulos ejecutores	12
Archivos TS/TSX en src	835
Archivos de test	333

MEDIDO EN EL BUILD · 2026-11-02 · commit 1552e63

D STACK

EJECUCIÓN

Next.js 16.3.3 · React 19.2 · App Router
TypeScript 5 · Tailwind v4 · OKLCH tokens
Drizzle ORM 0.45 · Supabase Postgres
Trigger.dev 4.7.2 · Sentry 11 · Vercel iad1

E ORDEN DE LECTURA RECOMENDADO

01 QUÉ ES — Contexto y actores — Lámina 01 ›
02 ORDEN — Capas y dependencias — Lámina 02 ›
03 EJECUCIÓN — Pipeline de escaneo — Lámina 03 ›
04 IA — Pool y failover — Lámina 04 ›
05 DATOS — Modelo relacional — Lámina 05 ›
06 DEFENSA — Seguridad y RLS — Lámina 06 ›
07 LEY — Reglas de oro — Lámina 07 ›
08 OPERACIÓN — Jobs y señales — Lámina 08

F PRINCIPIOS RECTORES

01 · RESILIENCIA
La app nunca depende de IA ni de servicios auxiliares. Excepción: el rate limit, que es fail-closed acotado (ADR-002 §16).

02 · FUENTE ÚNICA
Un solo registro de tools, un solo esquema SQL canónico, un solo punto de entrada por ruta (checks de CI).

03 · DEFENSA EN PROFUNDIDAD
RLS + egress-guard SSRF + CSP con nonce + rate limit + audit log. Ningún control es la única barrera.

04 · SIN EVIDENCIA NO HAY DONE
Ninguna afirmación de validación sin comando ejecutado y salida observada (CORE_SYSTEM §9).

DECLARACIÓN DE ALCANCE

SCAUDIT Pro es un monolito modular desplegado en Vercel: Next.js 16 (App Router) sobre Supabase Postgres con RLS, motor de inteligencia propio que expone 43 herramientas sobre redes públicas bajo un egress-guard anti-SSRF, y un pool de IA multi-proveedor con degradación graciosa. No hay Docker, Kubernetes ni Redis: la cola de escaneo y la caché distribuida viven en Postgres (ADR-008).

Este atlas describe el sistema tal como está en el repositorio, no una intención de roadmap. Cada lámina separa lo verificado en código de lo asumido; las cifras son conteos directos sobre el árbol de trabajo.

G GLOSARIO

RLS Row Level Security por claim JWT
Sink destino de telemetría o alertas
Tool herramienta registrada y ejecutable
TD / ADR deuda técnica / decisión registrada

STRATEGICAUDIT PRO — ATLAS TÉCNICO DOCUMENTO MAESTRO			CAD
Portada e índice general del atlas			
Nº PLANO	SCAUDIT-CAD-00	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	00 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO

CONTEXTO DEL SISTEMA · C4 L1

ACTORES · SISTEMA · SERVICIOS EXTERNOS · PROTOCOLOS

A ACTORES

ANALISTA / CISO

Dashboard, copilot,
reportes PDF

CONSUMIDOR API v1

API key Bearer
rate limit por key

CI / CD

Webhook firmado
HMAC SHA-256

SCAUDIT PRO · [SISTEMA]

Next.js 16 · Vercel iad1

EDGE

proxy.ts · CSP con nonce por request
HSTS preload · X-Frame-Options DENY · updateSession

WEB

App Router · 25 páginas · 3 layouts
next-intl es/en · PWA · Server Actions

API

78 route handlers en 25 dominios
Zod + withErrorHandler + withRateLimit

DOMINIO

ai · intelligence (core, executors, discovery, mitre)
security · notifications · reports (server-only)

DATOS

Drizzle ORM · Postgres Supabase · 78 tablas
RLS · outbox · scan_queue · caché L2

JOBS

Vercel Cron ×3 (garantizado) · CRON_SECRET
Trigger.dev: 27 archivos · 34 tasks · 10 schedules

B SERVICIOS EXTERNOS

TLS · RLS

SUPABASE

Postgres + Auth + RLS
pooler :6543 · directo :5432

HTTPS

POOL IA

OpenRouter primario
failover Groq → Gemini

SDK

TRIGGER.DEV

34 tasks · 10 schedules
opcional, no bloqueante

HTTPS

SIEM

Slack · PagerDuty
Splunk · Resend

OAuth

GOOGLE APIs

Search Console · GA4
OAuth refresh token

DSN

SENTRY

errores + trazas
túnel /monitoring

C PROTOCOLOS Y AUTENTICACIÓN

ORIGEN	DESTINO	PROTOCOLO	AUTENTICACIÓN	CONTROL DE BORDE
Navegador / PWA	Edge (proxy.ts)	HTTPS 443	Cookie de sesión Supabase	CSP nonce · HSTS · X-Frame-Options
API v1 consumidor	Route handler	HTTPS REST	Bearer API key (hash en BD)	withPublicApi · rate limit por key
Pipeline CI/CD	Webhook	HTTPS POST	Firma HMAC SHA-256	verifyWebhookSignature + egress re-check
Dominio	Postgres	TCP 6543 / 5432	service_role (server) o claims JWT	withRLS() por transacción
Dominio	Servicios OSINT	HTTPS saliente	según proveedor	egress-guard: solo IP pública
Vercel Cron	Route /api/cron/*	HTTPS	CRON_SECRET	comparación en tiempo constante

D LÍMITES Y SUPUESTOS

NOTAS

01 Monolito modular: sin Docker, Kubernetes ni Redis. La cola y la caché L2 viven en Postgres (ADR-008).
02 Trigger.dev es opcional: los crons de Vercel son el mecanismo garantizado de operación.
03 La IA es auxiliar: su caída degrada el copilot, nunca la disponibilidad de la app.
04 Región única iad1 declarada en vercel.json; no contrastada contra el panel de Vercel.

ALCANCE DEL PLANO

Incluye: frontend, API, motor, IA, datos, jobs y seguridad.
Excluye: internals de Supabase, Vercel y OpenRouter.
Nivel C4: L1 contexto · L2 contenedores · L3 componentes.
Fuente: código + ADR + registro de deuda del repo.

E SECUENCIA DE UN REQUEST AUTENTICADO

01 NAVEGADOR cookie de sesión → **02 proxy.ts** CSP + updateSession → **03 ROUTE** Zod + auth → **04 RATE LIMIT** ventana Postgres → **05 DISPATCHER** breaker + semáforo → **06 EXECUTOR** egress-guard → **07 withRLS** claims + rol → **08 JSON** RateLimit-* + datos

Toda la cadena ocurre server-side; el navegador solo recibe JSON o HTML ya autorizado.

STRATEGICAUDIT PRO — ATLAS TÉCNICO
ARQUITECTURA DE SOFTWARE

CAD

Quién usa el sistema y de qué depende

Nº PLANO	SCAUDIT-CAD-01	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	01 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO

CAPAS Y CONTENEDORES · C4 L2

SIETE CAPAS · DIRECCIÓN DE DEPENDENCIA · SUPERFICIES

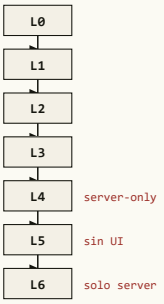
A CAPAS Y CONTENEDORES

L0 CLIENTE	**NAVEGADOR / PWA** standalone · SW · offline	**API v1** Bearer key + rate limit	**CI/CD** webhook con firma HMAC
L1 EDGE	**proxy.ts** CSP nonce + HSTS + headers	**updateSession()** refresh + redirect a /login	**Rate limit global** fail-closed acotado
L2 PRESENTACIÓN	**app/ (25 páginas)** dashboard · intelligence security · settings	**features/intelligence** components · hooks stores · lib	**Server Actions** audits · projects · reports
L3 API	**intelligence (24)** runs · tools · live	**public/v1 (7) + ai (4)** API key · copilot · report	**security (5) · projects (5)** audit · siem · csp · crud	**resto (33)** webhooks · cron · dominio
L4 DOMINIO	**intelligence/core** dispatcher · registry cache · breaker · semáforo risk-engine · scan-response	**executors (12)** dns · tls · osint · cve email · whois · takeover discovery · mitre	**ai/** ai-router · TASK_ROUTING failover · usage	**seguridad y salida** SIEM · HMAC · api-keys push · reportes PDF
L5 DATOS	**Drizzle ORM** schemas · 78 pgTable migraciones 68 · journal 68	**withRLS()** claims JWT + rol en 1 statement transaccional, nunca persistente	**Postgres Supabase** RLS · índices · outbox scan_queue · caché distribuida
L6 JOBS	**Vercel Cron ×3** siem 03:00 · uptime 03:30 ai-healthcheck 04:00	**Trigger.dev** 34 tasks · 10 schedules discovery · anomaly · queue	**On-demand** runProjectAudit · webhooks purga de cola · reportes

B REGLA DE DEPENDENCIA

SOLO HACIA ABAJO

Una capa no importa de la superior.



PROHIBIDO

cliente → DB directa
componente → ai-router
route → executor sin registry
job → UI

El cliente NUNCA conoce
keys, provider, fallback

C SUPERFICIES

ELEMENTO	N
Páginas	25
Route handlers	78
Dominios API	25
Tools	43
Ejecutores	12
Tablas	78

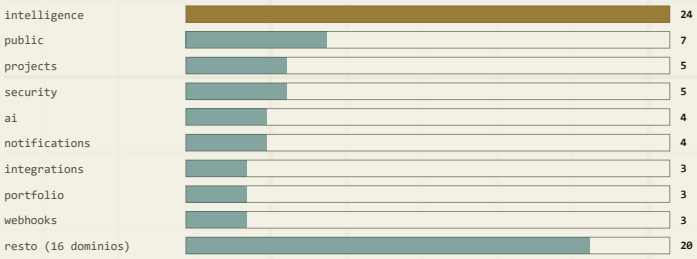
FRONTERA SERVER

src/server/** es server-only.
Secretos en env-secrets.ts.
service_role solo en admin.ts.

El client bundle no contiene
NINGUNA credencial: guard:secrets
falla el build si aparece.

Toda lectura multi-tenant pasa
por withRLS(userId).

D DISTRIBUCIÓN DE ROUTE HANDLERS · 78



NOTAS

01 L2 no habla con L5: las páginas consumen Server Actions o route handlers, nunca Drizzle directo.
02 L4 es el único lugar con lógica de negocio; L3 solo valida, autoriza y serializa.
03 L6 reutiliza los servicios de L4 — no duplica queries ni reglas de riesgo.
04 Los guards de CI impiden reintroducir capas eliminadas (check:entrypoint, cascade-drop).

STRATEGICAUDIT PRO — ATLAS TÉCNICO
ARQUITECTURA DE SOFTWARE

CAD

Estructura de capas y regla de dependencia

Nº PLANO	SCAUDIT-CAD-02	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	02 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO

MOTOR DE INTELIGENCIA · PIPELINE

12 ETAPAS · DOS MODOS · PRESUPUESTO DE EJECUCIÓN

A PIPELINE DE ESCANEO

POST /api/intelligence/runs → resultado persistido (camino síncrono) o encolado (FEATURE_SCAN_QUEUE)



B DOS MODOS DE EJECUCIÓN

SÍNCRONO (por defecto)

La ruta ejecuta el dispatcher y devuelve el resultado en el request.

Límite: maxDuration = 120 s.
Uso: 1–3 tools rápidas.

COLA (FEATURE_SCAN_QUEUE)

enqueueScanJob() sella el plan y escribe scan_queue; el worker drena con FOR UPDATE SKIP LOCKED y slots.

Fail-closed: si la cola está apagada, la ruta ejecuta en línea.

INVARIANTES DEL MOTOR

Toda salida HTTP pasa por egress-guard.
Todo tool se resuelve por el registry.
Toda persistencia usa withRLS(userId).
El breaker es fail-open; el rate limit, no.
La caché nunca devuelve datos de otro tenant.

C PRESUPUESTO DE EJECUCIÓN

ETAPA	LÍMITE	MECANISMO	CONSECUENCIA SI SE AGOTA
Request completo	120 s	maxDuration de la función	504; el cliente reintenta
Tool individual	timeout por tool	AbortSignal en el executor	Hallazgo marcado como error, resto continúa
Circuito	1.5 s	circuit-breaker fail-open	Se salta el proveedor y se degrada el resultado
Concurrencia	cupo por plan	semáforo + slots de scan_queue	El job espera en cola, no falla
Rate limit	ventana deslizante	Postgres (memoria acotada si cae)	429 con RateLimit-Reset

NOTAS

01 El dispatcher no conoce proveedores concretos: resuelve por toolId contra el registro único.
02 scan-response normaliza las claves (bug histórico de mayúsculas DNS corregido por accessors tipados).
03 El worker de cola reutiliza exactamente la misma lógica que el camino síncrono — no hay dos implementaciones.

STRATEGICAUDIT PRO — ATLAS TÉCNICO
ARQUITECTURA DE SOFTWARE

CAD

Cómo se ejecuta un escaneo de principio a fin

Nº PLANO	SCAUDIT-CAD-03	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	03 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO

POOL DE IA · ROUTING Y FAILOVER

CADENAS POR TAREA · ANTI-MONODEPENDENCIA · CONTRATOS

A ENTRADA Y CONTRATO

useAiChat (hook)
estado del chat · sin secretos
ETAPA 01

↓

POST /api/ai/copilot
Zod · rate limit 5/60 s
ETAPA 02

↓

callAIWithFallback()
taskType + messages
ETAPA 03

↓

Caché L1 → L2
TTL 5 min · LRU 200
ETAPA 04

↓

TASK_ROUTING[task]
cadena de modelos por tarea
ETAPA 05

B CADENAS POR TAREA (TASK_ROUTING)

general-chat — 20 s × 5

1º	2º	3º	4º	5º
or/free	omni	gemma-4	super	nano

meta-modelo primero · modelos :free verificados en vivo

copilot-remediation — 20 s × 5

1º	2º	3º	4º	5º
or/free	gemma-4	omni	super	ultra

meta-modelo primero · modelos :free verificados en vivo

incident-brief — 20 s × 5

1º	2º	3º	4º	5º
or/free	gemma-4	super	omni	ultra

meta-modelo primero · modelos :free verificados en vivo

seo-report (JSON) — 50 s × 2

1º	2º
or/free	gemma-4

meta-modelo primero · modelos :free verificados en vivo

C FAILOVER

OPENROUTER
primario · modelos :free

↓

GROQ
gpt-oss-120b · 0.65–1.1 s

↓

GEMINI
3.8-flash · 2.9–4 s

↓

ERROR GRACIOSO
sin filtrar trazas ni keys

El failover conserva el contrato: tools + JSON + self-heal.
Piso de 512 max_tokens (los modelos de reasoning lo consumen).
Solo usa el remanente de maxDuration si quedan > 8 s.

D JERARQUÍA DEL PROMPT (ANTI-INYECCIÓN)

[SYSTEM INSTRUCTIONS]
máxima prioridad · no sobrescribible
PRIORIDAD 3

›

[APPLICATION CONTEXT]
generado por la app · acotado
PRIORIDAD 2

›

[UNTRUSTED DATA]
OSINT, evidencias, logs · delimitado
PRIORIDAD 1

REGLA DURA
Datos externos NUNCA cambian las instrucciones del sistema. Salida validada por schema.

E CONTRATO DE SALIDA Y TELEMETRÍA

CAMPO	SIGNIFICADO
success / content	resultado útil para el cliente
modelUsed	prefijo groq:… o gemini:… en failover
latencyMs	medida real del proveedor
fromCache	true si sirvió L1 o L2
fallbackUsed	true si cambió de proveedor
tokens	input / output / total
correlationId	traza extremo a extremo, sin secretos

PERSISTENCIA Y LÍMITES

scheduleAiUsage() registra con after(): la invocación sobrevive al response; con fallback en tests/Trigger.dev.
Un fallo de telemetría NUNCA rompe la respuesta al usuario.

La key vive solo en envSecrets (server). El navegador nunca ve provider, cadena ni fallback.

Sin ninguna key el chat muestra onboarding; con la caída del pool, error accionable — no 'configura tu key'.

NOTAS

01 Los modelos JSON-críticos excluyen el meta-router: solo modelos con salida estructurada verificada en vivo.
02 Los evals con modelOverride miden al modelo real y no entran al failover.
03 Trade-off documentado: el free tier de Gemini puede usar el contenido para mejorar el producto.
04 El presupuesto de 120 s de la route se comparte entre la cadena primaria y el failover.

F QUÉ PASA SI…

NO HAY NINGUNA KEY
El chat muestra onboarding; el resto del producto sigue operativo. No es un error 500.

OPENROUTER RESPONDE 429
Se recorre la cadena y se pasa a Groq (0.65–1.1 s). La UI no alarma.

TODO EL POOL FALLA
Error accionable con correlationId; nunca se filtran trazas ni el nombre de la key.

STRATEGICAUDIT PRO — ATLAS TÉCNICO
ARQUITECTURA DE SOFTWARE

CAD

Cómo se elige, degrada y audita un modelo

Nº PLANO	SCAUDIT-CAD-04	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	04 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO

MODELO DE DATOS · ERD

TENANCY · INTELIGENCIA · ACCESO · IA · COLAS · OBSERVABILIDAD

A MODELO RELACIONAL — NÚCLEO

A · TENANCY Y PRODUCTO

users RLS
PK id · email · created_at
auth.users (Supabase)

projects RLS
PK id · FK user_id · domain
name · plan · health_score

audits RLS
PK id · FK project_id
status · score · ran_at

monitoring_schedules RLS
PK id · FK project_id · cron
enabled · last_run_at

keyword_targets RLS
PK id · FK project_id · term
position · volume · cpc

integrations RLS
PK id · FK project_id · provider
gsc · ga4 · bing · tokens

B · INTELIGENCIA

intelligence_investigations RLS
PK id · FK project_id · target · status
started_at · completed_at · summary

intelligence_tool_runs RLS
PK id · FK investigation_id · tool_id
ok · latency_ms · payload jsonb

intelligence_findings RLS
PK id · FK investigation_id · severity
confidence · mitre_id · evidence

intelligence_assets RLS
PK id · FK project_id · kind · value
first_seen · last_seen · source

dns_history / whois_history RLS
PK id · FK project_id · domain
snapshot jsonb · hash · captured_at

intelligence_run_events RLS
PK id · FK run_id · type · message
timeline del escaneo (polling 15 s)

C · ACCESO Y AUDITORÍA

developer_api_keys
PK id · FK user_id · hash · prefix
plan · expires_at · revoked_at

security_audit_logs
PK id · event_type · ip · user_id
payload jsonb · created_at

siem_alert_logs
PK id · rule · severity · channel
delivered · attempts · sent_at

webhook_configs RLS
PK id · FK project_id · url · events
secret (HMAC) · enabled

push_subscriptions
PK id · FK user_id · endpoint
p256dh · auth · created_at

plugin_instances RLS
PK id · FK project_id · plugin_id
config · enabled

D · IA Y ENTREGABLES

ai_usage
PK id · FK user_id · task_type
model_used · tokens · latency_ms

ai_health_logs
PK id · model · status · latency_ms
probed_at · error_code

reports RLS
PK id · FK project_id · kind · status
storage_path · generated_at

ai_report_jobs
PK id · FK report_id · progress
step · error · updated_at

remediation_actions
PK id · FK finding_id · action
approved_by · executed_at

E · COLAS Y EVENTOS

scan_queue
PK id · FK project_id · tool · target
status · plan · attempts · locked_at

scan_queue_slots
PK id · plan · capacity · in_use
cupo de concurrencia por plan

outbox_events
PK id · event_type · payload jsonb · status
attempts · dedupe_key · available_at

adversary_runs
PK id · FK project_id · scenario_id
status · findings · ran_at

audit_rules / project_audit_rules
PK id · FK project_id · rule_key
threshold · enabled

F · OBSERVABILIDAD

anomaly_detections
PK id · metric · z_score · severity
window_start · detected_at

uptime_logs
PK id · FK project_id · ok
response_time_ms · checked_at

web_vitals_logs
PK id · FK project_id · metric
value · device_type · session_id

app_logs
PK id · level · message · context
request_id · created_at

audit_logs / user_logs
PK id · actor · action · target
ip · user_agent · created_at

B CONVENCIONES

PK	clave primaria (uuid v4)
FK	clave foránea con índice
RLS	tabla con Row Level Security y policy por user_id
jsonb	payload versionado, nunca consultado por campo crítico
cascade	borrado en cascada auditado por check:cascade-drop
1 → N	relación padre → hijo (flecha gris)

PARIDAD ESQUEMA ⇔ MIGRACIONES

78 tablas pgTable y 68 migraciones SQL en el journal.
El drift no se tolera: db:drift-check, db:fk-guard,
db:index-guard y retention-index-check corren en CI.

Las migraciones deben aplicar desde cero sobre Postgres
real (job Integration) — no solo sobre una BD ya migrada.

C ARCHIVOS DE ESQUEMA · 25

Conteo por pgTable(); suma exacta del ERD

ARCHIVO	TABLAS
adversary.ts	8
ai-evals.ts	1
anomaly.ts	1
app-logs.ts	1
distributed-cache.ts	1
exec-briefs.ts	1
forecast.ts	1
health.ts	3
history.ts	2
idempotency.ts	1
index.ts	31
intelligence.ts	7
monitoring.ts	4

ARCHIVO	TABLAS
notifications.ts	1
outbox.ts	1
pdf-progress.ts	1
plugins.ts	2
push-subscriptions.ts	1
rate-limit-windows.ts	1
remediation.ts	1
scan-queue.ts	2
security-audit.ts	2
teams.ts	2
technologies.ts	1
user-logs.ts	1

POSTGRES EN LUGAR DE REDIS (ADR-008)

Un servicio menos que operar y asegurar:
caché L2 y cola viven en la misma BD
que ya tiene RLS y backups.

La cola usa FOR UPDATE SKIP LOCKED
y slots por plan para no saturar
la base con escaneos concurrentes.

Trade-off: la BD es también el cuello
de botella; por eso hay índices y
guards de retención en CI.

STRATEGICAUDIT PRO — ATLAS TÉCNICO
ARQUITECTURA DE SOFTWARE

CAD

Entidades del núcleo y sus relaciones

Nº PLANO	SCAUDIT-CAD-05	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	05 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO

SEGURIDAD · FRONTERAS DE CONFIANZA

5 CAPAS · 6 FRONTERAS · MODOS DE FALLA · RLS

A DEFENSA EN PROFUNDIDAD

L1 · EDGE
- CSP con nonce por request
- HSTS preload · X-Frame-Options DENY
- updateSession() refresca y redirige

L2 · API
- withErrorHandler + AppError tipados
- rate limit distribuido + allowlist
- validación Zod de todo payload

L3 · MOTOR
- egress-guard SSRF (CIDR + DNS)
- policy-enforcer de plan
- semáforo y timeouts por tool

L4 · DATOS
- withRLS(userId) por transacción
- service_role solo server
- secretos en env-secrets.ts

L5 · OBSERVABILIDAD
- security_audit_logs
- SIEM multi-canal + heartbeat
- Sentry con dataCollection mínimo

B FRONTERAS DE CONFIANZA

ID	FRONTERA	CONTROL REAL
TB-1	Cliente → Edge	CSP nonce · HSTS · X-Frame-Options · Referrer-Policy · report-uri
TB-2	Edge → Route	updateSession(): refresco de sesión y redirect a /login
TB-3	Route → Dominio	Rate limit fail-closed acotado · circuit breaker fail-open 1.5 s
TB-4	Dominio → Externo	egress-guard: CIDR privados v4/v6 + ::ffff: · DNS revalidado
TB-5	Dominio → DB	withRLS + claims JWT · admin solo server · secretos server-only
TB-6	Sistema → Webhook	Firma HMAC SHA-256 + suscripción de eventos

C MODO DE FALLA DECLARADO

COMPONENTE	MODO	COMPORTAMIENTO
Rate limit	FAIL-CLOSED	Si el store cae, sigue limitando en memoria + techo por instancia
Egress guard	FAIL-CLOSED	Ante duda de resolución, bloquea la salida
Circuit breaker	FAIL-OPEN	Servicio auxiliar: se salta y se degrada, nunca tumba la app
Caché L2	FAIL-OPEN	Se ignora y se consulta el origen
IA	DEGRADACIÓN	Onboarding si no hay key; failover; error accionable si todo falla

EGRESS GUARD · SSRF

Solo http: y https:.
Bloquea loopback, link-local, RFC1918, 0.0.0.0/8, 198.18/15, 169.254/16 y ::ffff:x.x.x.x.
Revalida cada redirect y usa User-Agent propio.

CABECERAS Y CSP

default-src 'self'
script-src 'nonce-…' 'strict-dynamic'
object-src 'none' · frame-ancestors 'none'
connect-src 'self' + Supabase
HSTS 31536000 · includeSubDomains
Permisos de navegador restringidos

D RLS — SECUENCIA TRANSACCIONAL

01	BEGIN	abre transacción
02	set_config('request.jwt.claims', claims, true)	claims con sub = userId
03	set_config('role', 'authenticated', true)	rol efectivo solo en la tx
04	…queries del callback…	policies filtran por sub
05	COMMIT	el rol vuelve al de sesión

INVARIANTES

Nunca SET ROLE sin LOCAL. Nunca confiar en el projectId del cliente. Nunca consultar sin RLS fuera del backend de jobs. Nunca devolver stack traces.

1 roundtrip por transacción
(TD-28a verificado en Postgres)

E AMENAZAS → CONTROL (STRIDE)

AMENAZA	SUPERFICIE	CONTROL
Spoofing	login / callback	Magic Link + allowlist de email + rate limit
Tampering	HTTP en tránsito	HSTS + upgrade-insecure-requests + egress-guard
Repudiation	acciones de usuario	security_audit_logs + exportador SIEM
Information disclosure	APIs multi-tenant	RLS + auth + service_role solo server
Denial of service	endpoints y motor	rate limit acotado + semáforos + timeouts
Elevation of privilege	datos de proyecto	RLS por claim sub + autorización owner-only

NOTAS

01 Los controles son independientes: la caída de uno no anula los demás (defensa en profundidad).
02 La autorización es owner-only: el user_id sale del token, jamás del body.
03 Los logs de seguridad se escriben con logSecurityEvent() y alimentan el exportador SIEM.

STRATEGICAUDIT PRO — ATLAS TÉCNICO
ARQUITECTURA DE SOFTWARE

CAD

Qué protege cada capa y cómo falla

Nº PLANO	SCAUDIT-CAD-06	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	06 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO

REGLAS DE ORO · CONSTITUCIÓN

16 INVARIANTES DE INGENIERÍA Y SU VERIFICACIÓN AUTOMÁTICA

A JERARQUÍA NORMATIVA

CONSTITUCIÓN → principios no negociables

CORE_SYSTEM → doctrina del copilot

ADR → decisiones con contexto

AGENTS.md → reglas operativas

CI / GUARDS → verificación automática

R-01 FAIL-CLOSED EN SEGURIDAD

Rate limit, egress guard y autorización niegan ante duda. Solo los auxiliares (breaker, caché) degradan a fail-open.

VERIFICA rate-limiter.test · egress-guard.fuzz

R-02 NINGÚN DATO SIN RLS

Toda lectura o escritura multi-tenant pasa por withRLS(userId). El id del cliente no es autorización.

VERIFICA rls.test · tests/security

R-03 SECRETOS SOLO SERVER

Keys, service_role y CRON_SECRET viven en env-secrets.ts. Nunca en bundle, logs ni respuestas.

VERIFICA guard:secrets

R-04 SALIDA EXTERNA VALIDADA

Toda petición HTTP del motor pasa por egress-guard: IP pública, protocolo permitido, redirects revalidados.

VERIFICA egress-guard.test

R-05 FUENTE ÚNICA DE TOOLS

Solo tool-registry.ts registra herramientas. Un tool nuevo no crea una segunda superficie de ejecución.

VERIFICA check:entrypoint · ADR-001

R-06 EL CLIENTE NO SABE DE IA

Componentes no conocen provider, fallback ni keys. Solo el hook y el contrato AIResponse.

VERIFICA CORE_SYSTEM §3

R-07 HUMANO ANTES DE IRREVERSIBLE

Recomendación → revisión → aprobación → ejecución → auditoría. La IA nunca ejecuta cambios destructivos.

VERIFICA CORE_SYSTEM §8

R-08 DATO EXTERNO = NO CONFIABLE

OSINT, evidencias y logs van delimitados; jamás sobrescriben instrucciones del sistema.

VERIFICA intelligence-context.test

R-09 LA APP NO DEPENDE DE LA IA

Sin key o con el pool caído, el producto sigue operativo; solo se degrada el copilot.

VERIFICA e2e-ai-router

R-10 MIGRACIONES DESDE CERO

Idempotentes, con stubs de plataforma y fail-closed: sin roles no hay verde silencioso.

VERIFICA Integration (Postgres real)

R-11 SIN EVIDENCIA NO HAY DONE

Ninguna afirmación de validación sin comando ejecutado y salida observada.

VERIFICA quality-gate · revisión

R-12 OWNER-ONLY POR DEFECTO

El acceso a datos de proyecto se deriva del ownership, no de membresías implícitas.

VERIFICA ADR-010 · migración 0052

R-13 PRESUPUESTO DE LATENCIA

120 s por route, IA ≤ 110 s, piso de 512 max_tokens en failover.

VERIFICA MODEL_TIMEOUTS · e2e

R-14 SEMÁNTICA, NO COLORES

UI solo con tokens OKLCH; WCAG 2.2 AA en ambos temas; animación respeta reduced-motion.

VERIFICA a11y.spec · design tokens

R-15 PARIDAD DE IDIOMA

Toda clave i18n existe en es y en; los prompts de IA también son bilingües.

VERIFICA guard:i18n

R-16 UN PUNTO DE ENTRADA

Una ruta, un handler; sin duplicar lógica entre camino síncrono y worker de cola.

VERIFICA check:entrypoint · review

CLÁUSULA DE BLOQUEO

Una violación de R-01 a R-08 bloquea el merge: son condiciones de seguridad, no preferencias de estilo. Las reglas R-09 a R-16 son condiciones de entrega y se verifican en el mismo pipeline. Excepción documentada únicamente vía ADR con fecha, motivo y control compensatorio.

STRATEGICAUDIT PRO — ATLAS TÉCNICO GOBIERNO DE INGENIERÍA			CAD
Invariantes no negociables del sistema			
Nº PLANO	SCAUDIT-CAD-07	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	07 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO

OPERACIÓN · JOBS Y OBSERVABILIDAD

CALENDARIO · SEÑALES · SIEM · RESPUESTA A INCIDENTES

A LÍNEA DE TIEMPO DE JOBS (UTC)

Alta frecuencia: SIEM y cola cada 5 min · uptime y anomalías cada 15 min · escaneo cada hora · discovery y adversary cada 6 h



B CATÁLOGO DE JOBS

JOB	DISPARO	EFECTO
siemExporterTask	*/5 min	detecta patrones y despacha alertas
drainScanQueue	*/5 min + wakeup	drena scan_queue con SKIP LOCKED
uptimeMonitor	*/15 min	comprueba uptime y latencia
periodicAnomalyDetection	*/15 min	Z-score sobre latencia y error rate
scheduledScanTask	cada hora	monitoring_schedules vencidos → audit
continuousDiscovery	cada 6 h	DNS brute, CT logs, shadow assets
periodicAdversarySimulation	cada 6 h	12 escenarios MITRE
apiKeyExpiryAlert	09:00	keys por expirar → SIEM
cleanupOldLogs	00:00	purga por retención

C SEÑALES Y SUMIDEROS

SEÑAL	DESTINO
Errores y trazas	Sentry /monitoring
Logs de app	app_logs
Eventos de seguridad	security_audit_logs
Alertas entregadas	siem_alert_logs
Salud de modelos	ai_health_logs
Web Vitals (RUM)	web_vitals_logs
Anomalías	anomaly_detections
Uptime	uptime_logs
Health público	/api/public/v1/health

D REGLAS SIEM

REGLA	PATRÓN	CANALES
Open redirect attack	múltiples intentos desde una IP	Slack · Email · PagerDuty
Rate limit bypass	IPs rotadas contra el limitador	Slack · Email
AI model failure	status=down en healthcheck	Slack · Email · PagerDuty
CSP spike	>10 violaciones en 5 min	Slack · Email
Auth failure burst	fallos de autenticación en 1 min	Slack · PagerDuty
API key expiry	keys que expiran en 1–7 días	Slack · Email
Heartbeat	ping cada 30 min	todos los canales

E RESPUESTA A INCIDENTE

01 · DETECTAR
alerta SIEM o health degradado

▼

02 · TRIAR
severidad, alcance, tenant

▼

03 · CONGELAR
breaker/flag, sin cambios destructivos

▼

04 · MITIGAR
rollback o failover documentado

▼

05 · VERIFICAR
health + evidencia ejecutada

▼

06 · REGISTRAR
postmortem en CHANGELOG

F ESTADO DE SALUD Y DEGRADACIÓN

OK
todos los controles responden

DEGRADED
IA o caché caída; producto operativo

DOWN
DB inaccesible o health 5xx

Health público: GET /api/public/v1/health devuelve status y dbConfigured sin filtrar detalles internos.
Toda alerta incluye correlationId; los reintentos del exportador son idempotentes por clave de evento.
El heartbeat de 30 min detecta el fallo silencioso del pipeline, no solo la caída del servicio.

G ENDPOINTS OPERATIVOS

ENDPOINT	AUTORIZACIÓN	FUNCIÓN
GET /api/public/v1/health	público	status + dbConfigured, sin detalles internos
GET /api/ai/healthcheck	CRON_SECRET o sesión	probes del pool + guard de env-parity
POST /api/security/siem/run	sesión + rol	ejecuta el exportador bajo demanda
GET /api/cron/siem · /api/cron/uptime	CRON_SECRET	jobs garantizados de Vercel
GET /api/intelligence/anomalies	sesión	filtra por proyecto, métrica y severidad

NOTAS

01 Vercel Cron es el mecanismo garantizado; Trigger.dev añade frecuencia pero su indisponibilidad no rompe la operación.
02 La purga de cola corre dentro del dispatcher diario: no consume un slot de cron propio.
03 Los jobs son idempotentes por diseño: reintentar no duplica hallazgos ni alertas.

STRATEGICAUDIT PRO — ATLAS TÉCNICO
OPERACIONES

CAD

Qué corre, cuándo y cómo se detecta un fallo

Nº PLANO	SCAUDIT-CAD-08	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	08 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO

SELECCIÓN DE FRAMEWORK

STACK EN USO · MATRIZ DE AJUSTE · DECISIÓN Y DISPARADORES

A STACK EN USO · UNA CAPA, UN FRAMEWORK

APLICACIÓN
Next.js
v16.3.3
App Router + RSC
78 route handlers
proxy.ts + Server Actions

INTERFAZ
React
v19.2.4
client + server components
Tailwind 4 · tokens OKLCH
recharts · reactflow · leaflet

DATOS
Drizzle ORM
v0.45.2
Postgres + RLS
68 migraciones
una sola capa de acceso

JOBS
Trigger.dev
v4.7.2
34 tasks · 10 crons
durable + reintentos
Vercel Cron de respaldo

CALIDAD
Vitest + Playwright
v4.1.11 · 1.59.1
333 archivos de test
guards estructurales en CI
a11y con axe

B MATRIZ DE AJUSTE · CANDIDATOS VS CRITERIOS DEL PROYECTO

CANDIDATO	RSC	API	SERVERLESS	ECOSISTEMA	I18N · PWA	MIGRACIÓN	VEREDICTO
Next.js 16 · App Router	●	●	●	●	●	—	EN USO · encaje total, migrar no aporta nada
React Router (Remix)	○	●	●	●	◐	◐	Alternativa React válida; pierde RSC y el proxy de Next
SvelteKit	○	●	●	○	●	○	Reescritura de la UI y de sus 5 librerías de visualización
Nuxt	○	●	●	○	●	○	Reescritura total; el ecosistema actual es React
Astro	◐	◐	●	◐	◐	◐	Correcto para el sitio público de marketing, no para el dashboard
NestJS + React	○	●	○	◐	◐	○	Duplica runtime y DI; no encaja en serverless
Hono + React	○	●	●	◐	○	◐	Útil como worker de API aparte, no como app

● cumple · ◐ parcial · ○ no cumple · — no aplica

C DECISIÓN

MANTENER NEXT.JS 16 · NO MIGRAR · ADR-011

01 Server-side por defecto: 78 handlers y 4 módulos «use server» mantienen keys y RLS fuera del cliente.

02 proxy.ts implementa CSP con nonce por request — está acoplado al runtime de Next 16.

03 Vercel nativo: maxDuration, cron de respaldo y región fija sin adaptador propio (vercel.json).

04 i18n cookie-based sin reestructurar URLs (ADR-003) y PWA ya servida desde public/.

05 Migrar exige reescribir 835 archivos TS/TSX y reintegrar cinco dependencias de UI (recharts, reactflow, react-pdf, leaflet, swagger).

D CUÁNDO REABRIR LA DECISIÓN

>50 % del tráfico
es contenido estático → Astro para el sitio público

Cómputo >120 s
o binarios nativos → contenedor solo para ese worker

Streaming de chat
→ Vercel AI SDK dentro del router actual, no un framework nuevo

API de terceros
estable → worker Hono aparte, mismo Postgres

Equipo de UI
mayoritariamente no-React → evaluar SvelteKit con presupuesto de 6 meses

E QUÉ NO AÑADIR (Y POR QUÉ)

NO · NestJS / Express
Duplica el runtime, rompe el modelo serverless y añade una segunda entrypoint (R-16).

NO · Redis / BullMQ
ADR-008: cola y caché L2 ya viven en Postgres; un servicio menos que operar.

NO · LangChain / LangGraph
El pool ya resuelve cadenas por tarea, failover, caché, presupuesto y self-heal de JSON.

NO · Docker / Kubernetes
Vercel cubre el despliegue; no hay binarios nativos ni procesos de larga vida.

F MAPA FRAMEWORK → CÓDIGO

proxy.ts — edge · CSP + sesión — CAPA 1
→ **app/** — 25 páginas · RSC — CAPA 2
→ **app/api/** — 78 handlers — CAPA 3
→ **server/** — dominio server-only — CAPA 4
→ **shared/db/** — 78 tablas — CAPA 5

El build de Next resuelve las cinco capas; no hay servidor propio ni proceso persistente.

MÉTODO Evaluación cualitativa contra los criterios que el proyecto ya exige (RSC, route handlers, serverless en Vercel, ecosistema React, i18n/PWA, coste de migración). No es un benchmark de rendimiento ni una comparativa de precios: los candidatos se puntúan por encaje arquitectónico, no por velocidad.

Versiones leídas de package.json en el build del 2026-11-02 · commit 1552e63.

STRATEGICAUDIT PRO — ATLAS TÉCNICO
DECISIÓN TÉCNICA
CAD

Por qué Next.js 16 es el framework correcto aquí

Nº PLANO	SCAUDIT-CAD-09	REV	1.0
ESCALA	N/A	FECHA	2026-11-02
LÁMINA	09 / 10	FORMATO	A4 · 210×297

DOCUMENTO GENERADO DESDE EL CÓDIGO Y LOS ADR DEL REPOSITORIO